Secure CAN Monitor: Full Report

Secure CAN Monitor: Full Report (work done, issues faced)

Date: 2026-11-12 (evening). Final evaluation: Saturday 2026-11-14. Project: M.Tech minor project. Detection-only Secure CAN Monitor in OP-TEE (Secure World) on Raspberry Pi 3 B (TF-A + OP-TEE 4.10 + Linux 6.7.0-rc6, MCP2518FD `can0`; `can1` is dead hardware).

Read this first. This is a *detection-only* monitor. The Pi 3 has no TZASC, so Secure World cannot stop Linux from doing anything. The keys are prototype values readable by root Linux. The event log is RAM-only, with no hash chain. **Every frame judged so far was CAN loopback or injected through the PTA by a software sender. Nothing here is evidence about a real CAN bus.** The independent second CAN path (Design 2, chip B) is not built.

---

1. Status at a glance

#	Component	Status	Evidence
C1	Baseline and hardware readiness	Done (software gate). N-04 found and fixed	`baseline/COMPONENT_1_RECORD.md`, `monitor/N04_SECURE_MEMORY_RESERVATION.md`
C2	Monitor foundation	Closed. Board 51 PASS, 2 PARTIAL, 0 FAIL of 53	`monitor/COMPONENT_2_GATE_CHECK.md`
C3	Core 1 integration	Complete, with recorded deviations	`monitor/COMPONENT_3_CORE1_CALL_LIST_AND_SYMBOL_DIFF.md`
C4	Timing and measurement	Closed with limits (floods, sender, histogram NOT DONE)	`monitor/COMPONENT_4_TIMING_AND_MEASUREMENT.md`
C5	Heartbeat and traffic deadline	Done on the board: 26 PASS, 0 FAIL, 1 skip	`baseline/c5_board_tests_run2_full_20261112.txt`
C6	Hardening	Done on the board for the flashed image (idle caps 6 PASS, negative tests 12 PASS). Two source changes written, not flashed	`monitor/COMPONENT_6_HARDENING.md`
C7	Independent CAN (chip B)	**Designed, not built** (no second board, no sender)	`monitor/COMPONENT_7_DESIGNED_NOT_BUILT.md`
C8	Soaks and final report	In progress. Soaks running	`RESULTS.md`

#	Component	Status	Evidence
		on the Pi; `RESULTS.md` sections 6 and 7 pending	

2. What was done

Earlier, before this phase (still valid)

- Real CAN pipeline on `can0` (loopback): classify, authenticate, tamper-detect, cross-core demo passes.
- OP-TEE reads the CAN chip over SPI0; its interrupt reaches Secure World.
- Core 1 reserved for Secure World and verified on hardware.
- C1 to C3 closed, C2 with 51 of 53 board checks passing.

This phase (2026-11-12)

1. **N-04 (secure memory reservation).** The device tree now reserves 0x10000000-0x10FFFFFF as `no-map`. Installed on the Pi, hash `e8ac38fa...`. Rule added to the build files. Not proven by a full image build, only by reproducing its command.
2. **F24 (heartbeat starvation).** Quantified with 0, 3, 8 and 24 flooding processes. Result: frame-submit worst case 10 ms, 271 ms, 553 ms, 1.18 s; late heartbeat answers 0, 0, 1, 8; ring entries lost 0, 0, 16, 149. The monitor stayed healthy (`starved=0`, no lock timeouts). Effect is false traffic alarms and late-answer events. The unprivileged route was closed by removing the `test` account from the `teeclnt` group on the Pi (not in the image build).
3. **C4 closed** with the open items marked NOT DONE (floods, hardware sender, gap histogram). R, grace and N_req were found in the original plan and recorded.
4. **C5 board acceptance.** Tests for tag and payload tampering, malformed frames, replay, duplicate, conflict, gaps, traffic timeout and recovery, counter wrap, heartbeat misuse (wrong nonce, stale, duplicate, unissued, late), consumer absence, `CONSUMER_NEVER_STARTED`, 1000-frame flood limiter, parallel callers, and two real reboots. Result: 26 PASS, 0 FAIL, 1 skip.
5. **C6 hardening.** Legacy debug commands refused in the hardened profile (56 of 56 refused over two runs, counted best-effort). Idle caps (6 PASS) and raw negative tests with deliberately wrong parameter types (12 PASS).
6. **Host verification.** Real sources with a mock platform under ASan and UBSan: 434 checks (production), 1493 (test-statistics build), 451 (UART flag on), 0 failed. Static checks: 58 on source, 61 with object code. Five bugs planted for the new tests were all caught. Earlier mutation run: 141 of 144 caught (3 equivalent), run on the 2026-11-09 sources and **not re-run after C6**.
7. **Written but not flashed.** `IDLE_EXPIRED` event (MODE_CHANGED detail 2) and a non-blocking UART `ALIVE` line behind a flag that is off. Both host-tested, built with 0 warnings, object-checked.
8. **Decisions D-A to D-F** (delegated by the user): no coalescing change; contention hint dropped; UART flag stays off; **the current hardened c16384 image is frozen as final**; `IDLE_EXPIRED` not flashed; soaks use software-injected frames; nested repos never pushed.
9. **Documentation and git.** Status board and dated log rewritten; plan with decisions; progress report; C7 record; `RESULTS.md` draft; cited-path checker (500 paths, 0 unresolved); source bundles refreshed. Committed after each operation; top-level repo pushed to `origin nov-2026-backup`.
10. **Soaks (in progress).** A detached chain on the Pi: 1 hour, then 10 hours, software sender at 100 ms period plus heartbeat responder. A laptop watcher samples the monitor every 60 s into `baseline/soak_watch_20261112.csv`. At the last sample read (about 2 hours of uptime, 14:26Z) the heartbeat state was ANSWERED and the frame counter was still rising. **That is an interim observation, not a result.** The verdict comes after the run ends (about 05:20 IST on 2026-11-13).

3. Measurements

Quantity	Value
Core 1 loop pass	26.6 ns; lock attempt 12.6 us; attempt interval about 448 us
Longest PTA lock hold	7.24 us (target below 100 us)
PTA call latency, one caller, idle	p50 3.88 ms, p99 4.30 ms
Stack on Core 1	worst case 2000 B of 4096 B; normal path 640 B (board watermark 688 B)
Traffic timeout	296.5 ms after last frame (limit 300 ms)

Quantity	Value
Constants	T 300 ms, H 1000 ms, D_req 500 ms, G 60 s, K_miss 3, ring 24 pinned + 40 ordinary

4. Issues faced (including my own mistakes)

Design and system issues

ID	Issue	Outcome
O-01	FIQ handler wrote onto the live Core 1 stack	Resolved by decision D1 Option B (FIQ masked in the Core 1 loop)
H1	Hidden `memcpy` inside a lock hold, found only by object-code inspection	Fixed; object-code check now in the static checks
N-04	Secure memory not reserved in the device tree	Fixed with `no-map` reservation; installed on the Pi
F24	The PTA is serialised, so flooding callers delay the heartbeat path	Quantified, mitigated for unprivileged users, **not preventable** for root or `teeclnt` members
F27	I claimed TIMEOUT/TRAFFIC_RECOVERED were not rate-limited	Wrong; the limiter exists. Claim withdrawn
F29	Refusal counter for legacy commands is best-effort (one trylock, drops on contention)	Documented; test expectation changed to `1 <= delta <= N`
O-10	Miss counter is a plain increment	Left as is (about 136 years to wrap); documented
UART	No adapter connected, so the boot log, stalled-UART test and `ALIVE` line are unverified	Code written behind an off flag; not flashed
Hardware	No second CAN board, no CAN sender, `can1` dead	C7 designed only; floods and histogram NOT DONE

My own mistakes (found and corrected)

- Claimed R, grace and N_req were undefined; they were in an older plan file (`~/.claude/plans/adaptive-doodling-iverson.md`).
- Mislabelled my T10b test (recovery) against the plan's T10b (O-10).
- Wrote "28 of 28" for the refusal tests; correct is 28 per run, 56 of 56 over two runs.
- Wrote "frame period" where the traffic deadline was meant; the mutation numbers pre-date C6.
- Two C5 test bugs: T22 compared the newest instead of the earliest pinned event; T17c answered an already-late request. Both fixed, original runs kept.
- First F24 3-flooder run was invalid (2,000,000 calls exceeded the 200,000 limit). Kept as INVALID, fixed, rerun.
- **A false object-code "pass" on empty disassembly files** (a stale log line made my watcher return early). Discarded, redone after checking both builds and that the disassembly was not empty.
- The UART digit routine's local array pulled in `__stack_chk_fail` on Core 1. Rewritten without an array.
- Builds with a relative 0= left 588 MB in `optee_os/`. Moved out and the script fixed.
- `make clean` removed tracked binaries; fixed with `git rm --cached` and `.gitignore`.
- BusyBox `delgroup` deleted nothing; replaced by editing `/etc/group`. `pkill -f` killed my own shell.
- R1 raw test failed (run 1) because of my wrong expectation; run 2 passed 12.

5. Known limits (not hidden)

- **Detection only.** No prevention of any kind.
- All frames software-injected or loopback. No real-bus timing, bus-off or flood evidence.
- Keys are prototype constants; root Linux can read them, so an HMAC is not provenance against it.
- A root Linux can stop answering or disable the path; only the UART going quiet would show it, and UART is not connected.
- Event log is RAM-only, not tamper-evident.
- F24: any process that can open `/dev/tee0` can cause false alarms and late-answer events.

- No “no false alarms” claim. Missed by construction: delays shorter than the deadline, exact retransmission of a valid frame, a sender restart (looks like a replay storm).
- Boot-ID uniqueness is a sample of 3 boots (plan asks for 20+).
- Design 2, UART verification, `IDLE_EXPIRED` and UART on the board, CAN/SPI floods, gap histogram, T5b, T4b, T18e on the board, and T24 for the debug profile: **not done, not claimed**.
- No off-laptop copy of `SD_Card_Backups/`.

6. What remains

1. Let the soaks finish (about 05:20 IST on 2026-11-13). No other load on the Pi.
2. Analyse the CSV and the end-of-run summaries against the pass criteria fixed in advance: zero BUSY after retries, zero lock timeouts, `starved=0` throughout, no panic or reboot, all heartbeat answers on time except possibly the first, Core 1 poll age bounded.
3. Fill `RESULTS.md` sections 6 and 7 honestly, run `verify_boot`, clean the Pi’s `/tmp`, update the status board, commit and push.
4. Optional: 20-reboot boot-ID sample (about 25 minutes).
5. Before Saturday: external copy of `SD_Card_Backups/`, repo freeze, refreshed bundles, demo rehearsal.

7. Recovery if anything fails

Flash only the 8 GB spare card (`scripts/card_helper.sh`), never the 32 GB original. Rollback image: hardened c16384 (`armstub8.monitor-hardened-c16384.bin`, sha256 `775ce3849a38...`, listed in `SD_Card_Backups/SHA256SUMS`).